Sprint 2 – S2_12 – Fundamentos de Vulnerabilidades

Inventário de Ativos e Vulnerabilidades

Matheus Moreli Durão Silva – 12621CBS217
Cibersegurança – Bacharelado – Noturno

Conceitos

Vulnerabilidade é uma falha ou fraqueza que pode ser explorada. Ameaça é algo ou alguém capaz de explorar uma vulnerabilidade. Risco é a combinação da possibilidade de exploração com o impacto no contexto do ativo. Não são sinônimos.

Dados verificáveis

CVE identifica uma vulnerabilidade divulgada publicamente; CWE classifica a fraqueza; CVSS registra uma pontuação técnica. O sistema também guarda fonte e data, ativo afetado, impacto, prioridade, tratamento e como o tratamento será verificado. A prioridade considera o contexto: uma mesma nota CVSS pode ser mais urgente em um ativo crítico.

Fontes de consulta

O programa CVE cataloga vulnerabilidades divulgadas; a NVD reúne dados de gestão e métricas; a CWE descreve fraquezas de software e hardware. Consultar a referência antes do cadastro impede apresentar suposição como fato.
CVE: https://www.cve.org/; NVD: https://nvd.nist.gov/; CWE: https://cwe.mitre.org/.

Caso real 1: CVE-2019-0708

A NVD descreve execução remota de código no Remote Desktop Services de versões antigas do Windows e classifica a fraqueza como CWE-416. Antes de associar ao notebook de demonstração, é necessário verificar versão do sistema e exposição do RDP. Tratamento: correção do fabricante e restrição do acesso remoto. Fonte: https://nvd.nist.gov/vuln/detail/CVE-2019-0708.

Caso real 2: CVE-2021-44228

A NVD registra falha no Log4j2 associada a JNDI e execução remota de código em configurações afetadas. O servidor de demonstração só estaria exposto se a aplicação usasse versão afetada de `log4j-core`. Tratamento: atualizar a biblioteca e dependências; verificar componentes instalados. Fonte: https://nvd.nist.gov/vuln/detail/CVE-2021-44228.

Limite da análise

Os ativos do JSON são fictícios. CVE real não prova que um equipamento real usa versão vulnerável. O estudo detalhado, incluindo impacto, tratamento e fonte primária do fornecedor, está em `docs/cves-analisados.md` no repositório principal.